CyberMate 分析报告

生成时间：未记录 | 工具版本：1.7.2（规则集 2026.15，提交 422628a） | https_hint：auto | 输入：2 项（成功 2 / 失败 0）
通道未判定：2 项（HSTS 类规则对这些输入未检查——没报不代表没问题；用 `--https-hint yes/no` 可指定；其中 2 项响应头含 `Strict-Transport-Security` 或 `Alt-Svc`（含 :443），可作为你判断通道的线索，但不是传输层证据）

结论

2 份报文共 22 条信号：0 条要立刻处理、6 条尽快修、5 条可选加固、10 条加固建议（有空再修）、1 条可忽略。五项相加等于总数（5 + 10 = 15 条 optional）；下面按影响排序列出该动手的部分。「0 条要立刻处理」只说明抓包里没有同时满足两项的证据——① 暴露面由证据确证、② 受影响对象已确证；缺口在哪一条都写在每条 rationale 里。这不代表站点安全：下面 6 条仍建议按优先级处理。

> **检查范围**：你提供的抓包里出现的 HTTP 响应头、Cookie 属性与请求侧配置，共 34 条规则。证据出处按容器不同：raw / curl / legacy（本工具的标记文本）是原文（可在文件里逐字搜到）；Burp(XML) 是解码后的报文文本（`base64="true"` 的元素在文件里是 base64 串，搜不到明文）；HAR 是按 name/value 重建的头行（头字段的 name 与 value 都能在文件里逐字搜到）；HAR 的**起始行/状态行**（如 `HTTP/1.1 200 OK`）由 `httpVersion` + `status` + `statusText` 三个字段重建，文件里搜不到这行原文——这也是重建。
>
> **不检查**：不验证漏洞是否可被利用、不发任何请求、不做注入/目录/弱口令扫描、不判断业务逻辑缺陷，也看不到抓包里没出现的响应。HAR 的 `cookies` / `queryString` 数组不参与判定（只看头行与 URL 原文，见输入注记）。
>
> **结论性质**：这是配置层信号 + 整改建议，不是漏洞报告；severity 的 high 表示「影响大、修复成本低，建议立刻处理」，**不等于本站已经被利用。**
>
> **`--redact` 的射程**：它只遮蔽 Cookie / `Authorization` 凭据的**值**（名字、属性、位置全部保留，因为规则判的就是这些）；**URL 查询参数的值不专门遮** —— 规则判的就是「哪个参数带了会话」，值本身就是证据，遮掉不可复核，遮罩层不会针对它做替换；但若它出现在被遮罩的头部行里（`Cookie:` / `Authorization:`），会随那一段一起被替换；**若 URL 里确有真凭据，请自行处理后再对外发送**；**不做站点匿名化** —— 域名、完整 URL、文件名在报告里仍是原文。对外发送前请自行判断哪些字段需要手工删除。

现在就要动手（6 条）

排序口径：按实际后果排（must-fix 先于 should-fix，同级按责任方），不按 severity 字母序，也不按命中数。标记「配置矛盾（功能问题）」的条目属于配置自相矛盾、后果是功能失效。

#	问题	谁改	改什么	怎么验证	不改会怎样	命中
1	`cookie.missing-httponly`	后端	在 Set-Cookie 里补 HttpOnly 属性，例如 `Set-Cookie: sid=...; HttpOnly; Secure; SameSite=Lax`	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -i httponly`	若本站存在可被利用的注入点（XSS）或第三方脚本，脚本可读到这枚 Cookie，进而带走登录态；抓包本身证不出是否存在这类注入点。	2
2	`cookie.missing-samesite`	后端	在 Set-Cookie 里补 `SameSite=Lax`（需要跨站携带时用 `SameSite=None; Secure`）	`curl -sI https://<域名>/ | grep -i '^set-cookie' |`	未声明 SameSite 时浏览器按各自的默认值处理：若浏览器按现代默认（Chrome 80+ / Safari 13.1+ / Firefox 96+ 均为 Lax）处理，跨站顶层	1

#	问题	谁改	改什么	怎么验证	不改会怎样	命中
				`grep -i samesite`	GET 导航仍会带上这枚 Cookie（取决于浏览器基线），但跨站的子请求（表单 POST、img/script/fetch）不会带；若内核较旧或未更新、按「不设」处理，则可能随任意跨站请求发出。实际影响取决于你的浏览器基线与该接口是否只接受跨站顶层跳转。	
3	`cookie.missing-secure`	后端	第一步：先把站点切到 HTTPS 并下发 HSTS——否则这条改不了：Strict Secure Cookies 下，非安全源上带 Secure 的 Cookie 会被浏览器拒绝，照做会直接丢登录态；第二步：切到 HTTPS 之后再加 Secure 属性，例如 Set-Cookie: sid=...; Secure; HttpOnly; SameSite=Lax	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -i secure`	若站点仍存在明文入口：这枚 Cookie 会随明文请求发出，同网段可旁听；若它承载登录态，后果等同泄露会话。本工具不验证这两件事是否成立。	1
4	`header.missing-coop`	后端	先判断：你的页面会被**别的站点**开窗或弹窗调用吗（OAuth 回调、嵌入式登录）？不会被调用 → 用 Cross-Origin-Opener-Policy: same-origin（最简单，直接切断 window.opener）；会被调用 → 用 same-origin-allow-popups，并让对端改用 postMessage 传值。（原文保留如下）响应头加 Cross-Origin-Opener-Policy: same-origin；需要被别的站点开窗调用的页面（OAuth 回调、嵌入式登录）改用 same-origin-allow-popups，并说明：OAuth / 支付回调这类 openers 场景（页面被第三方开窗/弹窗被调用）需要与对端确认用 postMessage 传值；同一站点下的多个子域（如 a.example.com / b.example.com）要逐个单独评估，不能一把改成 same-origin。不要退回到 unsafe-none：它让打开的窗口继续与本页共享浏览上下文，等于关闭了这项保护（与不设这个头等价）。边界情况：如果你的页面确实被别人跨域开窗、且依赖 window.opener 回传结果，这一项在当前架构下没有既安全又可用的取值（same-origin 与 same-origin-allow-popups 都会切断回传）——此时正确的做法是拆分独立子域或改用 postMessage 传值，而不是退回 unsafe-none	`curl -sI https://<域名>/ | grep -i '^cross-origin-opener-policy'`	同源打开的窗口之间仍共享浏览上下文，window.opener 可被用来做跨站脚本注入。另外：`unsafe-none` 本来就是浏览器的缺省值，所以「没配」在将来浏览器收紧默认值时能自动受益；把 `unsafe-none` 显式写死的站点则不会。这一点属于将来的收益，不是当下的额外暴露面。	1
5	`header.weak-csp`	后端	把 CSP 里的 `'unsafe-inline'` 换成 nonce/hash（如 `script-src 'nonce-<随机串>'`），把 `'unsafe-eval'` 去掉，把单独的 `*` 收窄成明确来源	`curl -sI https://<域名>/ | grep -i content-security-policy`	CSP 对注入脚本基本不起拦截作用，XSS 一旦出现就等于没有防线。	1

可以忽略（1 条）

共 1 条，属于加固建议或统计类 cookie 的正常配置，不影响可用性；明细见下方各输入小节。其中 0 条来自分析类 cookie（_ga / _gid / _fbp / _hjid / _clck）的过期时间，不计入风险。

有空再修（10 条）

共 10 条，按规则分行说明为什么改了更好但非必须；明细见下方各输入小节。

可选加固（5 条）

这一组按「是否需要独立的整改排期」划分：通常是加固建议，不构成立即被攻破的路径；明细见下方各输入小节。

摘要

指标	值
输入文件数	2
成功 / 失败	2 / 0
信号总数	22
severity：high	0
severity：medium	1
severity：low	13
severity：info	8
category：cookie	13
category：response-header	9
category：request	0
格式：har	0
格式：curl	0
格式：burp	0
格式：raw	2
格式：legacy	0
severity 口径	high = 影响大、修复成本低，建议立刻处理（不等于本站已被利用）； medium = 影响取决于具体上下文；急不急以 verdict 为准（不等于本站已被利用）； low = 加固建议；若 verdict 是 must-fix，说明后果是确定的，照样要立刻做；info = 提示；是否需要动手只看 verdict——info 也可能进「现在就要动手」（例如 Referrer-Policy 写成 unsafe-url，比不写更危险：URL 里的参数会被带到第三方）

聚合视图

规则	目标	命中	涉及文件	最高 severity	处置	谁改	改什么
`cookie.missing-httponly`	__Host-js_csrf	1	2	low	多数场景	后端	不要给这枚 Cookie 加 HttpOnly：CSRF token 必须能被前端 JS 读取才

规则	目标	命中	涉及文件	最高 severity	处置	谁改	改什么
					可忽略		能回显到请求头，加了会打断 CSRF 防护
`cookie.missing-httponly`	_octo	1	2	low	尽快修	后端	在 Set-Cookie 里补 HttpOnly 属性，例如 `Set-Cookie: sid=...; HttpOnly; Secure; SameSite=Lax`
`cookie.missing-httponly`	locale	1	2	low	尽快修	后端	在 Set-Cookie 里补 HttpOnly 属性，例如 `Set-Cookie: sid=...; HttpOnly; Secure; SameSite=Lax`
`cookie.missing-samesite`	locale	1	1	low	尽快修	后端	在 Set-Cookie 里补 `SameSite=Lax`（需要跨站携带时用 `SameSite=None; Secure`）
`cookie.missing-secure`	locale	1	1	low	尽快修	后端	第一步：先把站点切到 HTTPS 并下发 HSTS——否则这条改不了：Strict Secure Cookies 下，非安全源上带 Secure 的 Cookie 会被浏览器拒绝，照做会直接丢登录态；第二步：切到 HTTPS 之后再加 Secure 属性，例如 Set-Cookie: sid=...; Secure; HttpOnly; SameSite=Lax
`header.csp-wildcard-allowlist`	Content-Security-Policy	1	1	info	有空再修	后端	命中的是 `* ` / https://* / http://* / https: 这类「任意主机」来源。唯一收敛方向：换成具体主机名列表，或对脚本改用 nonce/hash
`header.missing-coop`	Cross-Origin-Opener-Policy	1	1	low	尽快修	后端	先判断：你的页面会被**别的站点**开窗或弹窗调用吗（OAuth 回调、嵌入式登录）？ 不会被调用 → 用 Cross-Origin-Opener-Policy: same-origin（最简单，直接切断 window.opener）；会被调用 → 用 same-origin-allow-popups，并让对端改用 postMessage 传值。（原文保留如下）响应头加 Cross-Origin-Opener-Policy: same-origin；需要被别的站点开窗调用的页面（OAuth 回调、嵌入式登录）改用 same-origin-allow-popups，并说明：OAuth / 支付回调这类 openers 场景（页面被第三方开窗/弹窗被调用）需要与对端确认用 postMessage 传值；同一站点下的多个子域（如 a.example.com / b.example.com）要逐个单独评估，不能一把改成 same-origin。不要退回到 unsafe-none：它让打开的窗口继续与本页共享浏览上下文，等于关闭了这项保护（与不设这个头等价）。边界情况：如果你的页面确实被别人跨域开窗、且依赖 window.opener 回传结果，这一项在当前架构下没有既安全又可用的取值（same-origin 与 same-origin-

规则	目标	命中	涉及文件	最高 severity	处置	谁改	改什么
							allow-popups 都会切断回传）——此时正确的做法是拆分独立子域或改用 postMessage 传值，而不是退回 unsafe-none
`header.weak-csp`	Content-Security-Policy	2	2	medium	尽快修	后端	把 CSP 里的 `'unsafe-inline'` 换成 nonce/hash（如 `script-src 'nonce-<随机串>'`），把 `'unsafe-eval'` 去掉，把单独的 `*` 收窄成明确来源
`cookie.expires-too-long`	会话身份类 cookie	3	2	low	有空再修	后端	把 Max-Age 收到 30 天以内，或改为会话 Cookie（不写 Max-Age/Expires）
`cookie.expires-too-long`	其它 cookie	3	2	low	有空再修	后端	建议按业务需要收紧有效期（例如 30 天以内）
`cookie.expires-too-long`	统计分析类 cookie	1	2	low	有空再修	产品或运营	统计/分析类 cookie 保留长期有效期即可，无需调整
`cookie.session-cookie-on-auth`	_gh_sess	1	1	info	有空再修	后端	按需补 `Max-Age=86400`（要持久登录）或明确保持会话 Cookie；关键操作要求二次验证
`header.missing-coep`	Cross-Origin-Embedder-Policy	2	2	info	有空再修	后端	注意 require-corp 会打断未声明 CORP/CORS 的第三方资源加载（图片/脚本/iframe 会缺）。**先判断你要不要跨源隔离**：只有需要 SharedArrayBuffer / 高精度计时 / Spectre 类隔离的应用（视频编辑、Web 游戏、WASM 高性能计算）才需要它；普通站点、营销页、博客不需要，加了只会增加页面损坏风险。做法：① 盘点页面上的第三方资源并逐一给它们声明 CORP 或 CORS 头；② 给本页面加 Cross-Origin-Embedder-Policy: require-corp，过渡期可用 credentialless 或先灰度一个页面；③ 观察异常后再扩大。两个注意事项：COEP 要与 COOP 成对配置（只加一个不会进入跨源隔离）；credentialless 在 Safari 上不支持，稳妥起见别把它当唯一方案；被嵌入的 iframe 目标自身仍需 CORP，否则照样加载失败
`header.missing-permissions-policy`	Permissions-Policy	2	2	info	有空再修	后端	响应头加 Permissions-Policy: camera=(self), microphone=(self), geolocation=(self)，只允许本站使用，再按业务需要逐项放开
`header.x-xss-protection-legacy`	X-Xss-Protection	1	1	info	有空再修	运维	显式写成 X-XSS-Protection: 0（不要用删除代替关闭：删除不等于关闭，旧内核仍默认启用）

聚合只是索引：下面「输入明细」保留全部 22 条 finding 与逐条证据，未删除任何一条。

输入明细

1. `py_github_head.raw`

输入注记：解析范围：本工具按「一份文件 = 一笔事务」解析，本份解析了 1 笔（请求 + 响应）。同一文件里的其它报文不会被分析——如需逐笔分析，请用 legacy 标记，或把报文拆成多个文件。

输入注记：宽松正文模式：声明与实际不符时降级不抛错（头部一字节不改）

格式：raw ｜ 通道：未判定——HSTS 类规则对本输入未检查 ｜ 事务数：1 ｜ 本文件全部信号 8 条（high 0 / medium 0 / low 4 / info 4）

`cookie.expires-too-long` low

字段	值
where	response
transaction	0
header	`Set-Cookie`
证据	`Set-Cookie: _octo=REDACTED; expires=Sun, 31 Oct 2027 13:58:42 GMT; domain=.github.com; path=/; secure; SameSite=Lax`
处置	optional（有空再修）
谁改	后端
改什么	把 Max-Age 收到 30 天以内，或改为会话 Cookie（不写 Max-Age/Expires）
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -iE 'max-age|expires'`
不改会怎样	长期有效会放大被窃取后的窗口，但不属必须动。
依据	「_octo」的 Expires=Sun, 31 Oct 2027 13:58:42 GMT 距固定基准 2026-01-01 超过 400 天（基准固定，保证隔天重跑结论一致）。
参考	RFC 6265bis §4.1.2.2, OWASP WSTG-SESS-02

`cookie.expires-too-long` low

字段	值
where	response
transaction	0
header	`Set-Cookie`
证据	`Set-Cookie: logged_in=REDACTED; expires=Sun, 31 Oct 2027 13:58:42 GMT; domain=.github.com; path=/; HttpOnly; secure; SameSite=Lax`
处置	optional（有空再修）
谁改	后端
改什么	把 Max-Age 收到 30 天以内，或改为会话 Cookie（不写 Max-Age/Expires）
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -iE 'max-age|expires'`
不改会怎样	长期有效会放大被窃取后的窗口，但不属必须动。
依据	「logged_in」的 Expires=Sun, 31 Oct 2027 13:58:42 GMT 距固定基准 2026-01-01 超过 400 天（基准固定，保证隔天重跑结论一致）。

字段	值
参考	RFC 6265bis §4.1.2.2, OWASP WSTG-SESS-02

`cookie.missing-httponly` low

字段	值
where	response
transaction	0
header	`Set-Cookie`
证据	`Set-Cookie: _octo=REDACTED; expires=Sun, 31 Oct 2027 13:58:42 GMT; domain=.github.com; path=/; secure; SameSite=Lax`
处置	should-fix（尽快修）
谁改	后端
改什么	在 Set-Cookie 里补 HttpOnly 属性，例如 `Set-Cookie: sid=...; HttpOnly; Secure; SameSite=Lax`
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -i httponly`
不改会怎样	若本站存在可被利用的注入点（XSS）或第三方脚本，脚本可读到这枚 Cookie，进而带走登录态；抓包本身证不出是否存在这类注入点。
依据	普通 Cookie「_octo」没有 HttpOnly 属性，脚本可读；名字不像会话凭据（按名字推断，未确认），影响相对较低。
参考	RFC 6265bis §4.1.3, CWE-1004

`header.missing-coop` low

字段	值
where	response
transaction	0
header	`Cross-Origin-Opener-Policy`
证据	`HTTP/1.1 200 OK`
处置	should-fix（尽快修）
谁改	后端
改什么	先判断：你的页面会被**别的站点**开窗或弹窗调用吗（OAuth 回调、嵌入式登录）？ 不会被调用 → 用 Cross-Origin-Opener-Policy: same-origin（最简单，直接切断 window.opener）； 会被调用 → 用 same-origin-allow-popups，并让对端改用 postMessage 传值。（原文保留如下）响应头加 Cross-Origin-Opener-Policy: same-origin；需要被别的站点开窗调用的页面（OAuth 回调、嵌入式登录）改用 same-origin-allow-popups，并说明：OAuth / 支付回调这类 openers 场景（页面被第三方开窗/弹窗被调用）需要与对端确认用 postMessage 传值；同一站点下的多个子域（如 a.example.com / b.example.com）要逐个单独评估，不能一把改成 same-origin。不要退回到 unsafe-none：它让打开的窗口继续与本页共享浏览上下文，等于关闭了这项保护（与不设这个头等价）。边界情况：如果你的页面确实被别人跨域开窗、且依赖 window.opener 回传结果，这一项在当前架构下没有既安全又可用的取值（same-origin 与 same-origin-allow-popups 都会切断回传）——此时正确的做法是拆分独立子域或改用 postMessage 传值，而不是退回 unsafe-none
怎么验证	`curl -sI https://<域名>/ | grep -i '^cross-origin-opener-policy'`
不改会怎样	同源打开的窗口之间仍共享浏览上下文，window.opener 可被用来做跨站脚本注入。另外：`unsafe-none` 本来就是浏览器的缺省值，所以「没配」在将来浏览器收紧默认值时能自动受益；把 `unsafe-none` 显式写死的站点则不会。这一点属于将来的收益，不是当下的额外暴露面。

字段	值
依据	COOP 缺失：同源打开的窗口之间仍共享浏览上下文；当页面存在可被诱导跳转或 opener 引用时，window.opener 会成为跨站脚本注入面。证据取本响应起始行。只按头名与值匹配，未做完整语义解析。
参考	MDN: Cross-Origin-Opener-Policy

`cookie.session-cookie-on-auth` info

字段	值
where	response
transaction	0
header	`Set-Cookie`
证据	`Set-Cookie: _gh_sess=REDACTED; path=/; HttpOnly; secure; SameSite=Lax`
处置	optional（有空再修）
谁改	后端
改什么	按需补 `Max-Age=86400`（要持久登录）或明确保持会话 Cookie；关键操作要求二次验证
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -iE 'max-age|expires'`
不改会怎样	关掉浏览器就要重新登录；若被他人拿到这枚 Cookie，在有效期内可直接冒用。
依据	鉴权相关 Cookie「_gh_sess」既无 Max-Age 也无 Expires：关闭浏览器即失效，可能是有意设计，仅作提示。
参考	RFC 6265bis §4.1.2

`header.missing-coep` info

字段	值
where	response
transaction	0
header	`Cross-Origin-Embedder-Policy`
证据	`HTTP/1.1 200 OK`
处置	optional（有空再修）
谁改	后端
改什么	注意 require-corp 会打断未声明 CORP/CORS 的第三方资源加载（图片/脚本/iframe 会缺）。**先判断你要不要跨源隔离**：只有需要 SharedArrayBuffer / 高精度计时 / Spectre 类隔离的应用（视频编辑、Web 游戏、WASM 高性能计算）才需要它；普通站点、营销页、博客不需要，加了只会增加页面损坏风险。做法：① 盘点页面上的第三方资源并逐一给它们声明 CORP 或 CORS 头；② 给本页面加 Cross-Origin-Embedder-Policy: require-corp，过渡期可用 credentialless 或先灰度一个页面；③ 观察异常后再扩大。两个注意事项：COEP 要与 COOP 成对配置（只加一个不会进入跨源隔离）；credentialless 在 Safari 上不支持，稳妥起见别把它当唯一方案；被嵌入的 iframe 目标自身仍需 CORP，否则照样加载失败
怎么验证	`curl -sI https://<域名>/ | grep -iE '^cross-origin-(embedder|opener)-policy'`；同时用浏览器控制台看有无 `CORP/CORS` 报错
不改会怎样	无法声明只加载明确授权的跨域资源，也就用不上依赖隔离的强特性（如 SharedArrayBuffer）。
依据	COEP 缺失：页面无法声明「只加载明确授权的跨域资源」，因此也用不上依赖隔离的强特性（如 SharedArrayBuffer）。证据取本响应起始行。只按头名与值匹配，未做完整语义解析。
参考	MDN: Cross-Origin-Embedder-Policy

`header.missing-permissions-policy` info

字段	值
where	response
transaction	0
header	`Permissions-Policy`
证据	`HTTP/1.1 200 OK`
处置	optional（有空再修）
谁改	后端
改什么	响应头加 Permissions-Policy: camera=(self), microphone=(self), geolocation=(self)，只允许本站使用，再按业务需要逐项放开
怎么验证	`curl -sI https://<域名>/ | grep -i '^permissions-policy'`
不改会怎样	缺这个头不会让跨源 iframe 获得这些能力（camera/microphone/geolocation 的默认允许列表本来就是 self）；真正后果是**无法进一步收紧**——不能用 () 彻底关掉，也不能只放给某个合作方。
依据	该 HTML 响应没有 Permissions-Policy：无法限制摄像头、麦克风、地理位置等浏览器特性。本轮只看有无，不校验允许列表内容。证据取本响应起始行。
参考	MDN: Permissions-Policy

`header.weak-csp` info

字段	值
where	response
transaction	0
header	`Content-Security-Policy`
证据	▶ 证据（4214 字符，点击展开）
处置	optional（有空再修）
谁改	后端
改什么	把 CSP 里的 `'unsafe-inline'` 换成 nonce/hash（如 `script-src 'nonce-<随机串>'`），把 `'unsafe-eval'` 去掉，把单独的 `*` 收窄成明确来源
怎么验证	`curl -sI https://<域名>/ | grep -i content-security-policy`
不改会怎样	CSP 对注入脚本基本不起拦截作用，XSS 一旦出现就等于没有防线。
依据	CSP 含弱来源：style-src:unsafe-inline（仅非脚本类指令命中，影响较低）。只按指令名与来源标记匹配，未做完整 CSP 语法解析。
参考	CSP Level 3 §6.1, CWE-79

2. `py_dropbox_home.raw`

输入注记：解析范围：本工具按「一份文件 = 一笔事务」解析，本份解析了 1 笔（请求 + 响应）。同一文件里的其它报文不会被分析——如需逐笔分析，请用 legacy 标记，或把报文拆成多个文件。

输入注记：规范化文本含 latin-1 之外的字符，改用 utf-8 编码

输入注记：宽松正文模式：声明与实际不符时降级不抛错（头部一字节不改）

格式：raw ｜ 通道：未判定——HSTS 类规则对本输入未检查 ｜ 事务数：1 ｜ 本文件全部信号 14 条（high 0 / medium 1 / low 9 / info 4）

`header.weak-csp` medium

字段	值
where	response
transaction	0
header	`Content-Security-Policy`
证据	▶ 证据（2272 字符，点击展开）
处置	should-fix（尽快修）
谁改	后端
改什么	把 CSP 里的 `'unsafe-inline'` 换成 nonce/hash（如 `script-src 'nonce-<随机串>'`），把 `'unsafe-eval'` 去掉，把单独的 `*` 收窄成明确来源
怎么验证	`curl -sI https://<域名>/ | grep -i content-security-policy`
不改会怎样	CSP 对注入脚本基本不起拦截作用，XSS 一旦出现就等于没有防线。
依据	CSP 含弱来源：script-src:unsafe-eval、script-src:unsafe-inline、style-src:unsafe-inline、style-src:unsafe-eval（高风险指令命中）。只按指令名与来源标记匹配，未做完整 CSP 语法解析。
参考	CSP Level 3 §6.1, CWE-79

`cookie.expires-too-long` low

字段	值
where	response
transaction	0
header	`Set-Cookie`
证据	`Set-Cookie: gvc=REDACTED; Path=/; Expires=Thu, 30 Oct 2031 14:09:42 GMT; HttpOnly; Secure; SameSite=None`
处置	optional（有空再修）
谁改	产品或运营
改什么	统计/分析类 cookie 保留长期有效期即可，无需调整
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -iE '_ga|_gid|_fbp'`
不改会怎样	名字像统计/分析类 Cookie（名字推断，本工具未从抓包证实其用途）。若确为统计类，长期有效期是常态、无需调整；若这枚 Cookie 承载登录态，长期有效会放大被窃取后的窗口，建议按会话 Cookie 处理。
依据	「gvc」的 Expires=Thu, 30 Oct 2031 14:09:42 GMT 距固定基准 2026-01-01 超过 400 天（基准固定，保证隔天重跑结论一致）。
参考	RFC 6265bis §4.1.2.2, OWASP WSTG-SESS-02

`cookie.expires-too-long` low

字段	值
where	response
transaction	0

字段	值
header	`Set-Cookie`
证据	`Set-Cookie: t=REDACTED; Path=/; Domain=dropbox.com; Expires=Sun, 31 Oct 2027 14:09:42 GMT; HttpOnly; Secure; SameSite=None`
处置	optional（有空再修）
谁改	后端
改什么	建议按业务需要收紧有效期（例如 30 天以内）
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -iE 'max-age|expires'`
不改会怎样	建议按业务需要收紧有效期。
依据	「t」的 Expires=Sun, 31 Oct 2027 14:09:42 GMT 距固定基准 2026-01-01 超过 400 天（基准固定，保证隔天重跑结论一致）。
参考	RFC 6265bis §4.1.2.2, OWASP WSTG-SESS-02

`cookie.expires-too-long` low

字段	值
where	response
transaction	0
header	`Set-Cookie`
证据	`Set-Cookie: __Host-js_csrf=REDACTED; Path=/; Expires=Sun, 31 Oct 2027 14:09:42 GMT; Secure; SameSite=None`
处置	optional（有空再修）
谁改	后端
改什么	建议按业务需要收紧有效期（例如 30 天以内）
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -iE 'max-age|expires'`
不改会怎样	建议按业务需要收紧有效期。
依据	「__Host-js_csrf」的 Expires=Sun, 31 Oct 2027 14:09:42 GMT 距固定基准 2026-01-01 超过 400 天（基准固定，保证隔天重跑结论一致）。
参考	RFC 6265bis §4.1.2.2, OWASP WSTG-SESS-02

`cookie.expires-too-long` low

字段	值
where	response
transaction	0
header	`Set-Cookie`
证据	`Set-Cookie: __Host-ss=REDACTED; Path=/; Expires=Sun, 31 Oct 2027 14:09:42 GMT; HttpOnly; Secure; SameSite=Strict`
处置	optional（有空再修）
谁改	后端
改什么	把 Max-Age 收到 30 天以内，或改为会话 Cookie（不写 Max-Age/Expires）

字段	值
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -iE 'max-age|expires'`
不改会怎样	长期有效会放大被窃取后的窗口，但不属必须动。
依据	「__Host-ss」的 Expires=Sun, 31 Oct 2027 14:09:42 GMT 距固定基准 2026-01-01 超过 400 天（基准固定，保证隔天重跑结论一致）。
参考	RFC 6265bis §4.1.2.2, OWASP WSTG-SESS-02

`cookie.expires-too-long` low

字段	值
where	response
transaction	0
header	`Set-Cookie`
证据	`Set-Cookie: locale=REDACTED; Path=/; Domain=dropbox.com; Expires=Thu, 30 Oct 2031 14:09:42 GMT`
处置	optional（有空再修）
谁改	后端
改什么	建议按业务需要收紧有效期（例如 30 天以内）
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -iE 'max-age|expires'`
不改会怎样	建议按业务需要收紧有效期。
依据	「locale」的 Expires=Thu, 30 Oct 2031 14:09:42 GMT 距固定基准 2026-01-01 超过 400 天（基准固定，保证隔天重跑结论一致）。
参考	RFC 6265bis §4.1.2.2, OWASP WSTG-SESS-02

`cookie.missing-httponly` low

字段	值
where	response
transaction	0
header	`Set-Cookie`
证据	`Set-Cookie: __Host-js_csrf=REDACTED; Path=/; Expires=Sun, 31 Oct 2027 14:09:42 GMT; Secure; SameSite=None`
处置	ignore（多数场景可忽略）
谁改	后端
改什么	不要给这枚 Cookie 加 HttpOnly：CSRF token 必须能被前端 JS 读取才能回显到请求头，加了会打断 CSRF 防护
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -iE 'csrf|xsrf'`
不改会怎样	加了 HttpOnly 会让前端拿不到 token，表单提交/接口调用直接失败（功能中断）
依据	「__Host-js_csrf」是 CSRF 令牌 Cookie：前端必须用 JS 读出它再回填到请求头或表单，**不能加 HttpOnly** —— 加了前端读不到 token，登录与提交会直接失败。所以这条不是漏配，是有意不加；该防的是 CSRF 本身（SameSite + 服务端 token 校验）。
参考	RFC 6265bis §4.1.3, CWE-1004

`cookie.missing-httponly` low

字段	值
where	response
transaction	0
header	`Set-Cookie`
证据	`Set-Cookie: locale=REDACTED; Path=/; Domain=dropbox.com; Expires=Thu, 30 Oct 2031 14:09:42 GMT`
处置	should-fix（尽快修）
谁改	后端
改什么	在 Set-Cookie 里补 HttpOnly 属性，例如 `Set-Cookie: sid=...; HttpOnly; Secure; SameSite=Lax`
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -i httponly`
不改会怎样	若本站存在可被利用的注入点（XSS）或第三方脚本，脚本可读到这枚 Cookie，进而带走登录态；抓包本身证不出是否存在这类注入点。
依据	普通 Cookie「locale」没有 HttpOnly 属性，脚本可读；名字不像会话凭据（按名字推断，未确认），影响相对较低。
参考	RFC 6265bis §4.1.3, CWE-1004

`cookie.missing-samesite` low

字段	值
where	response
transaction	0
header	`Set-Cookie`
证据	`Set-Cookie: locale=REDACTED; Path=/; Domain=dropbox.com; Expires=Thu, 30 Oct 2031 14:09:42 GMT`
处置	should-fix（尽快修）
谁改	后端
改什么	在 Set-Cookie 里补 `SameSite=Lax`（需要跨站携带时用 `SameSite=None; Secure`）
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -i samesite`
不改会怎样	未声明 SameSite 时浏览器按各自的默认值处理：若浏览器按现代默认（Chrome 80+ / Safari 13.1+ / Firefox 96+ 均为 Lax）处理，跨站顶层 GET 导航仍会带上这枚 Cookie（取决于浏览器基线），但跨站的子请求（表单 POST、img/script/fetch）不会带；若内核较旧或未更新、按「不设」处理，则可能随任意跨站请求发出。实际影响取决于你的浏览器基线与该接口是否只接受跨站顶层跳转。
依据	「locale」没有 SameSite 属性，跨站请求可能带上它（浏览器默认策略因版本而异，不能当作已设置）。
参考	RFC 6265bis §4.1.4, CWE-1275

`cookie.missing-secure` low

字段	值
where	response
transaction	0
header	`Set-Cookie`

字段	值
证据	`Set-Cookie: locale=REDACTED; Path=/; Domain=dropbox.com; Expires=Thu, 30 Oct 2031 14:09:42 GMT`
处置	should-fix（尽快修）
谁改	后端
改什么	第一步：先把站点切到 HTTPS 并下发 HSTS——否则这条改不了：Strict Secure Cookies 下，非安全源上带 Secure 的 Cookie 会被浏览器拒绝，照做会直接丢登录态；第二步：切到 HTTPS 之后再加 Secure 属性，例如 Set-Cookie: sid=...; Secure; HttpOnly; SameSite=Lax
怎么验证	`curl -sI https://<域名>/ | grep -i '^set-cookie' | grep -i secure`
不改会怎样	若站点仍存在明文入口：这枚 Cookie 会随明文请求发出，同网段可旁听；若它承载登录态，后果等同泄露会话。本工具不验证这两件事是否成立。
依据	普通 Cookie「locale」没有 Secure 属性，在明文信道上可能被发出。
参考	RFC 6265bis §4.1.3, CWE-614

`header.csp-wildcard-allowlist` info

字段	值
where	response
transaction	0
header	`Content-Security-Policy`
证据	▶ 证据（2272 字符，点击展开）
处置	optional（有空再修）
谁改	后端
改什么	命中的是 `*` / https://* / http://* / https: 这类「任意主机」来源。唯一收敛方向：换成具体主机名列表，或对脚本改用 nonce/hash
怎么验证	`curl -sI https://<域名>/ | grep -i '^content-security-policy' | grep -E '(default-src|script-src|object-src)[^;]*\*'`
不改会怎样	`*` 允许任意来源，白名单形同虚设，XSS 的外部载入通道仍然是通的。
依据	CSP 里出现通配来源：connect-src:https://*、font-src:https://*、frame-src:https://*、img-src:https://*、media-src:https://*、style-src:https://*（仅非脚本类指令命中，影响较低）。`*` / `https://*` / `http://*` / `https:` 都等于放行任意主机；应改成具体主机名，或改用 nonce/hash。只按指令名与来源标记匹配，未做完整 CSP 语法解析。
参考	MDN: CSP source values（* 通配）

`header.missing-coep` info

字段	值
where	response
transaction	0
header	`Cross-Origin-Embedder-Policy`
证据	`HTTP/1.1 200 OK`
处置	optional（有空再修）
谁改	后端

字段	值
改什么	注意 require-corp 会打断未声明 CORP/CORS 的第三方资源加载（图片/脚本/iframe 会缺）。**先判断你要不要跨源隔离**：只有需要 SharedArrayBuffer / 高精度计时 / Spectre 类隔离的应用（视频编辑、Web 游戏、WASM 高性能计算）才需要它；普通站点、营销页、博客不需要，加了只会增加页面损坏风险。做法：① 盘点页面上的第三方资源并逐一给它们声明 CORP 或 CORS 头；② 给本页面加 Cross-Origin-Embedder-Policy: require-corp，过渡期可用 credentialless 或先灰度一个页面；③ 观察异常后再扩大。两个注意事项：COEP 要与 COOP 成对配置（只加一个不会进入跨源隔离）；credentialless 在 Safari 上不支持，稳妥起见别把它当唯一方案；被嵌入的 iframe 目标自身仍需 CORP，否则照样加载失败
怎么验证	`curl -sI https://<域名>/ | grep -iE '^cross-origin-(embedder|opener)-policy'`；同时用浏览器控制台看有无 `CORP/CORS` 报错
不改会怎样	无法声明只加载明确授权的跨域资源，也就用不上依赖隔离的强特性（如 SharedArrayBuffer）。
依据	COEP 缺失：页面无法声明「只加载明确授权的跨域资源」，因此也用不上依赖隔离的强特性（如 SharedArrayBuffer）。证据取本响应起始行。只按头名与值匹配，未做完整语义解析。
参考	MDN: Cross-Origin-Embedder-Policy

`header.missing-permissions-policy` info

字段	值
where	response
transaction	0
header	`Permissions-Policy`
证据	`HTTP/1.1 200 OK`
处置	optional（有空再修）
谁改	后端
改什么	响应头加 Permissions-Policy: camera=(self), microphone=(self), geolocation=(self)，只允许本站使用，再按业务需要逐项放开
怎么验证	`curl -sI https://<域名>/ | grep -i '^permissions-policy'`
不改会怎样	缺这个头不会让跨源 iframe 获得这些能力（camera/microphone/geolocation 的默认允许列表本来就是 self）；真正后果是**无法进一步收紧**——不能用 () 彻底关掉，也不能只放给某个合作方。
依据	该 HTML 响应没有 Permissions-Policy：无法限制摄像头、麦克风、地理位置等浏览器特性。本轮只看有无，不校验允许列表内容。证据取本响应起始行。
参考	MDN: Permissions-Policy

`header.x-xss-protection-legacy` info

字段	值
where	response
transaction	0
header	`X-Xss-Protection`
证据	`X-Xss-Protection: 1; mode=block`
处置	optional（有空再修）
谁改	运维
改什么	显式写成 X-XSS-Protection: 0（不要用删除代替关闭：删除不等于关闭，旧内核仍默认启用）

字段	值
怎么验证	`curl -sI https://<域名>/ | grep -i '^x-xss-protection'`
不改会怎样	旧版 XSS 过滤器已被现代浏览器移除或忽略，留着不会增加防护，反而在某些旧内核上可被用来放大 XSS。
依据	X-XSS-Protection 处于启用态（值 1）。该头已被现代浏览器移除或忽略，旧版 XSS 过滤器本身可被用于绕过 CSP 或放大 XSS；正确的处理是显式写成 X-XSS-Protection: 0。删除该头不等于关闭（旧内核仍默认启用），因此不把删除当推荐动作。
参考	OWASP Secure Headers Project: X-XSS-Protection

证据完整性

无证据完整性告警

规则覆盖

状态	条数
hit	16
clean	33
skipped	4
not-applicable	6
not-triggered	9

> **0 命中要分四种读法**：`clean` 是「判据前提成立、检查后未命中」（确实看过、确实没中）；`not-applicable` 是「看过前提，判定这条规则对这份输入没意义」（不是没看）；`not-triggered` 是「规则已启用，但本次输入没触发它的判据」（不是没问题，是没机会判）；`skipped` 是「证据不足，想看看不了」，**也包含判据前提不可知**（例如传输方式未知，具体原因见下方 skip 原因表）。四者混着读会把「没测」当成「没问题」。

既无命中也无 clean 的规则（9 条）

这些规则既没有命中、也没有「看过但没中」；说明它们的判据前提在这批抓包里没成立。**这不等于「没有问题」，也不等于「工具没看」**——原因要么是不适用（例如没有明文 HTTP 响应、没有 CORS 相关头），要么是证据不足（例如通道未知）。要确认风险状态，得补上能让前提成立的样本。

规则	不适用	证据不足
`header.missing-hsts`	0	2
`header.hsts-short-max-age`	0	2
`header.cors-wildcard-with-credentials`	0	0
`header.cors-reflect-origin`	0	0
`header.cors-null-origin`	0	0
`request.cookie-over-http`	2	0
`header.csp-report-only-only`	0	0
`header.missing-corp`	2	0
`header.h2-connection-specific`	2	0

skipped 原因（逐条）

输入	规则	原因
`py_github_head.raw`	`header.missing-hsts`	`传输方式未知（https_hint=None），无法判断 HSTS 是否生效`
`py_github_head.raw`	`header.hsts-short-max-age`	`传输方式未知（https_hint=None），无法判断 HSTS 是否生效`
`py_dropbox_home.raw`	`header.missing-hsts`	`传输方式未知（https_hint=None），无法判断 HSTS 是否生效`
`py_dropbox_home.raw`	`header.hsts-short-max-age`	`传输方式未知（https_hint=None），无法判断 HSTS 是否生效`

附录

规则清单

rule_id	标题	依据
`cookie.missing-httponly`	Set-Cookie 缺少 HttpOnly 属性	RFC 6265bis §4.1.3, CWE-1004
`cookie.missing-secure`	Set-Cookie 缺少 Secure 属性	RFC 6265bis §4.1.3, CWE-614
`cookie.missing-samesite`	Set-Cookie 缺少 SameSite 属性	RFC 6265bis §4.1.4, CWE-1275
`cookie.samesite-none-without-secure`	SameSite=None 但缺少 Secure	RFC 6265bis §4.1.4, CWE-1275
`cookie.domain-too-wide`	Cookie Domain 过宽（单标签域）	RFC 6265bis §4.1.2.3, CWE-1275
`cookie.expires-too-long`	Cookie 有效期过长	RFC 6265bis §4.1.2.2, OWASP WSTG-SESS-02
`cookie.prefix-violation`	Cookie 名称前缀约束被违反	RFC 6265bis §4.1.3, CWE-1004
`cookie.session-cookie-on-auth`	鉴权相关 Cookie 无持久化属性（会话 Cookie）	RFC 6265bis §4.1.2
`header.missing-hsts`	HSTS 未声明或已失效	RFC 6797 §6.1, OWASP Secure Headers
`header.hsts-short-max-age`	HSTS max-age 短于 180 天	RFC 6797 §6.1.1
`header.missing-nosniff`	缺少 X-Content-Type-Options: nosniff	OWASP Secure Headers, CWE-436
`header.missing-frame-options`	缺少有效帧保护（X-Frame-Options / CSP frame-ancestors）	OWASP Secure Headers, CWE-1021
`header.weak-csp`	CSP 含弱指令（unsafe-inline / unsafe-eval / 单独 *）	CSP Level 3 §6.1, CWE-79
`header.cors-wildcard-with-credentials`	CORS 通配来源与凭据同时出现	Fetch Standard §3.2, CWE-942
`header.cors-reflect-origin`	CORS 反射请求 Origin 并放行凭据	Fetch Standard §3.2, CWE-942
`header.cors-null-origin`	CORS 允许 null 来源	Fetch Standard §3.2, CWE-942
`header.server-version-leak`	Server / X-Powered-By 泄露版本号	OWASP WSTG-INFO-02
`header.missing-referrer-policy`	缺少 Referrer-Policy	OWASP Secure Headers
`header.cache-on-sensitive`	敏感响应缺少 Cache-Control: no-store	OWASP WSTG-ATHN-06, CWE-525
`request.sensitive-param-in-url`	查询串携带会话类参数	OWASP WSTG-ATHN-05, CWE-598
`request.get-with-body`	GET/HEAD 请求带正文	RFC 9110 §9.3.1
`request.cookie-over-http`	明文 HTTP 上传输 Cookie	OWASP WSTG-SESS-02, CWE-319

rule_id	标题	依据
`request.duplicate-param`	同名查询参数重复且值不同	OWASP WSTG-INPV-04, CWE-235
`header.x-xss-protection-legacy`	X-XSS-Protection 处于启用态（该头已被现代浏览器废弃）	OWASP Secure Headers Project: X-XSS-Protection
`header.csp-missing`	HTML 响应完全没有 CSP	MDN: Content-Security-Policy
`header.csp-wildcard-allowlist`	CSP 的关键指令里出现裸 *（无方案限制）	MDN: CSP source values（* 通配）
`header.csp-report-only-only`	只有 Report-Only，没有强制生效的 CSP	MDN: Content-Security-Policy-Report-Only
`header.missing-permissions-policy`	HTML 响应缺少 Permissions-Policy	MDN: Permissions-Policy
`header.missing-coop`	COOP 缺失或被显式关闭	MDN: Cross-Origin-Opener-Policy
`header.missing-coep`	COEP 缺失或被显式关闭	MDN: Cross-Origin-Embedder-Policy
`header.missing-corp`	非 HTML 资源未声明 Cross-Origin-Resource-Policy	MDN: Cross-Origin-Resource-Policy
`header.referrer-policy-unsafe`	Referrer-Policy 的取值比不写更差（unsafe-url 等）	MDN: Referrer-Policy, OWASP Secure Headers Project: Referrer-Policy
`header.cross-domain-policies-not-none`	X-Permitted-Cross-Domain-Policies 存在但不是 none	OWASP Secure Headers Project: X-Permitted-Cross-Domain-Policies
`header.h2-connection-specific`	HTTP/2 响应里出现连接专属头（connection / keep-alive / transfer-encoding / upgrade / proxy-connection）	RFC 9113 §8.2.2 Connection-Specific Header Fields

已知局限

1. curl -v 不承载正文：适配器按「无正文」处理，并把 [data not shown] 记进 notes。
2. raw 的请求/响应分界按声明长度消费后再找状态行；正文里恰有一行以 HTTP/ 开头且声明长度不可用时，可能误判分界。
3. HAR 不补 Content-Length：适配器不伪造头，源报文没有定界信息时正文不落进原始字节里；但条目声明了 postData 时 `request.get-with-body` 仍会触发（判据取自 postData，不是 CL）。
4. HTTP/2、HTTP/3 的版本串会被归一（`h2`/`h3`/`h2c`/`HTTP/2` → `HTTP/2.0` 等）才能通过请求行校验；本工具不实现长连接与帧层语义（HAR 里的 h2 头已经是解码后的明文头）。
5. Burp 的 <url>/<host>/<mimetype>/<extension>/<comment> 只进 notes，不参与判定。
6. 正文为 gzip/deflate 时解压后只查敏感字段字面量（证据仍取 Content-Encoding 那一行原文，解压内容不进报告）；br/zstd 标准库无实现，仍记 not-applicable 并写明编码名。
7. 证据以规范化文本（canonical_text）为基准，不是原始文件；HAR 等格式的原文里找不到头行原文属正常。
8. 本工具只列信号，不下漏洞结论，也不发起任何网络请求。